

中興保全科技股份有限公司 中保智慧宅 115年滲透測試

滲透測試報告(初測)

個別修補建議報告



中華民國 115 年 07 月 21 日

機密等級：機密

版本號：v1.0



目錄

壹、風險等級判定標準	1
貳、 弱點風險等級統計表	2
參、 弱點名稱統計表	2
肆、 弱點檢測語法與佐證說明	3
(1). 低. HTTP Response Header安全設定不足	3
伍、 結論與建議	4



壹、風險等級判定標準

• 弱點(漏洞)之風險等級

本標準是依據作業系統或設備及網頁存在之弱點，由本團隊綜合相關資訊安全知識、證據及經驗，參酌風險評估方法論(OWASP Risk Rating Methodology)，分別就弱點之可利用度、常見程度、偵測難度等面向，評估攻擊成功的可能性 (Likelihood)，來進行安全風險分級，如下表所示。

風險等級	說明
極高度風險	對組織可造成嚴重傷害，如可取得核心系統權限、影響範圍不止單一系統、機敏資料可被大量竄改或竊取等重大衝擊。
高度風險	對組織可造成直接傷害，如網站、設備和資訊儲存管理者權限取得、程式執行、個資洩露或服務中斷等。或僅造成間接傷害，但仍可能於多次嘗試攻擊之後造成直接傷害。
中度風險	不會立即造成傷害，但惡意人士可能藉此獲得重要資訊，進行下一步攻擊，如原始檔洩露、網頁錯誤訊息等。
低度風險	洩露網站相關或其他資訊，但較難被利用於進行攻擊，如預設頁面、目錄列舉。



貳、弱點風險等級統計表

檢測目標	系統	弱點 總數	極高	高	中	低	整體風 險等級
https://smarthome.myv ita.com.tw	中保智慧宅	1	0	0	0	1	低風險

參、弱點名稱統計表

風險 等級	弱點名稱	弱點數量
低	HTTP Response Header安全設定不足	1



肆、弱點檢測語法與佐證說明

(1). 低. HTTP Response Header安全設定不足

弱點名稱	HTTP Response Header安全設定不足
問題網址	https://smarthome.myvita.com.tw
問題參數	Server設定
測試語法	透過檢測工具shcheck進行檢核，檢查Header有無未設置的安全性設定。
初測截圖	檢核結果顯示 Header 未設置Cross-Origin-Embedder-Policy、Cross-Origin-Resource-Policy、Cross-Origin-Opener-Policy。 <pre>https://googleads.g.doubleclick.net https://www.googleadservices.com https://d.line-scdn.net https://connect.facebook.net https://cdn.taboola.com https://trc.taboola.com https://static.cloudflareinsights.com https://*.tagtoo.co style-src: 'self' 'unsafe-inline' https://fonts.googleapis.com https://maxcdn.bootstrapcdn.com font-src: 'self' data: https://fonts.gstatic.com https://maxcdn.bootstrapcdn.com img-src: 'self' data: https://www.google-analytics.com https://www.googletagmanager.com https://*.google.com https://*.google.com.tw https://*.gstatic.com https://sp.analytics.yahoo.com https://googleads.g.doubleclick.net https://www.googleadservices.com https://www.facebook.com https://*.facebook.com https://*.line-scdn.net https://tr.line.me https://trc.taboola.com https://*.taboola.com https://static.cloudflareinsights.com connect-src: 'self' https://www.google-analytics.com https://analytics.google.com https://*.google.com https://s.yimg.com https://*.yimg.com https://www.facebook.com https://*.facebook.com https://googleads.g.doubleclick.net https://stats.g.doubleclick.net https://*.line-scdn.net https://*.taboola.com https://static.cloudflareinsights.com https://*.run.app https://*.conversionapigateway.com https://*.tagtoo.co frame-src: 'self' https://www.google.com https://www.googletagmanager.com https://www.youtube.com https://youtube.com https://www.recaptcha.net https://recaptcha.net https://www.facebook.com https://td.doubleclick.net https://bid.g.doubleclick.net object-src: 'none' base-uri: 'self' form-action: 'self' https://logistics.ecpay.com.tw frame-ancestors: 'self' [*] Header X-Permitted-Cross-Domain-Policies is present! (Value: none) [*] Header Referrer-Policy is present! (Value: strict-origin-when-cross-origin) [*] Header Permissions-Policy is present! (Value: accelerometer=(self), camera=(self), geolocation=(self), gyroscope=(self), magnetometer=(self), microphone=(self), payment=(self), usb=(self)) [!] Missing security header: Cross-Origin-Embedder-Policy [!] Missing security header: Cross-Origin-Resource-Policy [!] Missing security header: Cross-Origin-Opener-Policy [!] Headers analyzed for https://smarthome.myvita.com.tw [*] There are 7 security headers [-] There are not 3 security headers</pre>
複測截圖	(待複測後將依據檢測結果新增此處截圖)
修補建議	請參考章節「結論與建議」
備註說明	



伍、 結論與建議

本次滲透測試服務中，共發現受測目標系統含有下列漏洞，建議之修補方式請參考下列表格：

風險等級	弱點名稱	弱點數量	修補建議
低	HTTP Response Header安全設定不足	1	內容安全策略(Content-Security-Policy)或X-Content-Security-Policy都是限制瀏覽器存取網站時可否加載外部靜態資源(javascript、css等)，兩者差異只在支援的瀏覽器不同。設定後可限制「載入來源白名單」、「限制inline程式碼」、「限制eval函式使用」以及「避免Sniffer」。建議設定為[default-src 'self']，代表只能引用自己網站目錄下的javascript、css，而不能引用外部網站。